Cloud Misconfiguration and the Private Right of Action: A Technical and Legal Analysis of the Tea App Data Breach

Alex Frebowitz

Dec 12, 2025 6 min read

Summary

- The breach was not caused by one flaw but by failure to manage technical debt (leaving private data on unencrypted legacy systems) and a complete lack of basic DevSecOps practices.
- The Tea app faces legal exposure across jurisdictions for exposed PII, Sensitive Personal Information, which triggers CCPA/BIPA private rights of action and GDPR monetary penalties for disclosure of health-related data.
- The scandal exposes a vulnerable user base to doxxing and harassment. Preventing future disasters requires adopting Privacy-by-Design, mandating data minimization/deletion, and enforcing secure secrets management and regular third-party security audits.



KeremYucel via Getty Images

The Tea application (the “Tea app”) is a woman only dating safety platform. The company marketed itself as a platform that allows users to communicate with each other about their past, current, and prospective romantic interests in a secure forum. In July 2025, the Tea app discovered a data breach comprised of unauthorized access to several of the app’s databases. The Tea app, now facing legal and public relations repercussions, serves as a case study in how platforms must be accountable to protect end users’ Personally Identifiable Information (PII).

The most egregious breach involved publication of 72,000 images that were *publicly* accessible through a single Google Cloud Service (GCS) bucket, managed by Firebase, that lacked proper authentication and access controls. [1] Approximately 13,000 of those leaked images were selfies and government issued photo IDs (including driver’s licenses and passports) submitted for user verification. [2] The remaining images, approximately 59,000, were sourced from user posts, comments, and direct messages. [3]

A separate breach, arising from an entirely distinct vulnerability, was also detected. In this instance, hackers took advantage of the Tea app’s lack of database encryption at rest. This oversight likely included the hardcoding or insecure storage of an Application Programming Interface (API) [4] key, which

hackers extracted, likely via reverse engineering the app's client, to gain unauthorized access to the database. This exposed over 1.1 million private user messages sent from as early as 2023. [5]

Who Was Affected

The leak was confined to users who registered profiles before February 2024. [6] The vulnerability arose when the Tea app integrated data from its old legacy data system to its new infrastructure. Whenever the data migration happened, the GCS bucket and separate message database were improperly configured within the new Access Control List (ACL) or Identity and Access Management (IAM) policies, resulting in excessive access permissions or missing authentication requirements for the legacy data endpoints. [7] The breach was especially egregious considering the subject matter of the messages. Women detailed their experiences with abuse and infidelity, and shared health concerns. Unfortunately, these messages and images, many of them government-issued IDs, were shared on public forums, exposing users to risks including doxxing, identity theft, and harassment more generally.

Inferences from the Breaches on Tea App's Company Operations

The nature of the breach, which was enabled by the several vulnerabilities explained above, highlights several flaws in the Tea app's operational priorities and cybersecurity posture.

First, the Tea app likely prioritized rapid growth over investing in secure scaling, which would have included data cleansing and decommissioning of legacy data infrastructure. This would explain why the breach was confined to users who signed up *before February 2024*: the developers failed to securely retire, migrate, or encrypt old data when storage practices were updated.

Second, although the Tea app was available across all US jurisdictions, the developers failed to implement a "Privacy-by-Design" framework for data governance. Though the company's privacy policy stated data for user verification would only be retained for as long as necessary and then deleted, the exposure of 13,000 government-issued IDs proves that PII was *retained* beyond the principle

of storage limitation. [8]

Lastly, the development team either lacked knowledge of fundamental cloud security configuration (also referred to as DevSecOps) or knowingly failed to enforce basic internal security audits - cybersecurity was apparently not a priority. [9]

Data Privacy Implications: A Multi-Jurisdictional View

Liability for a breach of this sort, involving unencrypted PII and sensitive private messages, is enhanced under various jurisdictions. While the following does not cover every jurisdiction, it represents a sampling of the various frameworks under which Tea app may face legal repercussions.

There are already lawsuits filed in Illinois alleging violations of the Biometric Information Privacy Act (BIPA). [10] The BIPA requires companies to obtain written consent and publish a data retention policy before collecting facial geometry (classified as biometric data under the Act). [11] If companies fail to meet those requirements, BIPA allows for a private class action to recover damages. The Tea app solicited selfies and photo IDs for verification but failed to implement reasonable safeguards to protect the data. Therefore, the unauthorized disclosure that followed exposed the company to liability for statutory damages, the primary remedy sought in BIPA class actions, though the courts have not yet ruled on the merits.

California's data privacy framework derives from its statute, the California Consumer Privacy Act (the CCPA) which is amended by the California Privacy Rights Act (the CPRA) [12] . The CCPA/CPRA allows a private right of action for breaches of nonencrypted or nonredacted PII when an entity fails to implement reasonable security protocols. [13] Furthermore, the CCPA/CPRA designates certain data, such as a government-issued ID, as Sensitive Personal Information (SPI, this definition is specific to the CCPA/CPRA) because its publication exposes victims to a high risk of identity theft. A breach of SPI under this framework allows a plaintiff to recover without needing to show actual harm.

Pennsylvania, in contrast to Illinois and California, does not have a specific data privacy statute *yet* (though the state may be on the precipice of passing one). [14]

Instead Pennsylvania courts rely on common-law torts and other consumer protection statutes to evaluate claims, such as negligence or various privacy torts. Under this framework, a claimant could allege negligent data stewardship due to the Tea app's failure to implement "reasonable security measures" as defined by Pennsylvania common law. [15]

The European Union (EU) passed the General Data Protection Regulation (the GDPR), which member states of the EU used to model their respective nation's statutes regarding data privacy. Article 7 requires that any collection or analysis of data requires the subject of that data to provide consent that is freely given, specific, informed, and unambiguous. Under Article 4(15) of the GDPR, health-related information is a special category of personal data. The Tea app made assurances to users that data retention would be for the minimum time necessary, and that private messages would be private. Additionally, the Tea app failed to implement reasonable safeguards as required by the GDPR, such as end-to-end encryption and coherent data retention policies. Because Tea app, at the very least, controlled the collection of the data, it would be liable as a data controller under the GDPR. Considering this, pursuant to Article 83(5) of the GDPR, a member state of the EU may impose a fine of up to €20 million or 4% of the total worldwide annual turnover, *whichever is higher*.

Public Relations Nightmare and Trust Implications

Aside from any legal implications, this is a public relations disaster because the scandal represents the Tea app's failure to live up to one of its primary goals: safety. The app was ostensibly marketed as a "safe space" for women, including for those seeking advice on domestic violence or abuse. [16] The conventional wisdom in responding to a crisis like this is to release a clear and responsive statement, that is transparent about what went wrong, and in a timely fashion. The Tea app, however, initially responded by downplaying the severity of the breach and seemingly minimizing the concerns of those affected. Whether the Tea app will recover from this is yet to be determined, but much can be learned by anyone working with app development or data privacy.

Action Items to Avoid This

Development teams should consider the following, which address the specific failures seen in the Tea app breach:

- **Enforce mandatory encryption.** Implement End-to-End Encryption (E2EE) for private messages. All other sensitive data (PII, photos, IDs, messages) must be encrypted at rest and in transit (using mandatory certificate pinning).

- **Audit cloud configurations regularly.** Treat cloud storage buckets (like GCS or AWS S3) as high-risk assets. Implement automated Cloud Security Posture Management tools to continuously scan for and immediately flag public read/write permissions or unauthorized access.

- **Implement a strict data minimization and deletion policy.** Adopt a "Collect Less, Store Less" or “Zero Retention” data approach. If a government ID is used for single-use verification, it must be securely and verifiably deleted immediately after verification, as promised in the privacy policy.

- **Retire legacy systems securely and audit database security whenever there is a change in the environment.** Never leave old or unused databases and storage buckets connected or unsecured. All "legacy data systems" should be properly decommissioned and wiped after all data is migrated or deleted.

- **Implement a secure secrets management protocol.** Never hardcode API keys, database credentials, or client tokens directly into the application's source code. Use a secure vault or key management service.

- **Conduct periodic biometric compliance checks.** If using facial recognition or geometry for verification, especially in a jurisdiction where a BIPA or GDPR framework applies, ensure legal compliance first. Platforms must prompt and attain explicit, written consent from users and must publish a publicly available retention schedule for that biometric data.

- **Segregate and protect high-risk data.** Sensitive PII (government-issued IDs, biometrics) must be stored in a physically and logically separate environment with its own heightened access controls, and isolated from

general user uploaded content and messages.

- **Invest in third-party penetration testing and security auditing.** Budget for regular (reasonable based on the particulars) independent security audits and penetration tests to discover configuration flaws and API vulnerabilities that internal teams often overlook.

Endnotes

1. *Tea Dating App Breach Reveals Major Data Privacy Gaps in Rapidly Growing Platforms*, JD Supra (Aug. 8, 2025), https://www.jdsupra.com/legalnews/tea-dating-app-breach-reveals-major-1269005/ (last visited Dec. 11, 2025).

2. Katie Collins, *The Tea App Data Breach: What Was Exposed and What We Know About the Class Action Lawsuit*, CNET (July 30, 2025), https://www.cnet.com/tech/services-and-software/the-tea-app-data-breach-what-was-exposed-and-what-we-know-about-the-class-action-lawsuit/ (last visited Dec. 11, 2025).

3. *Tea Dating App Breach Reveals Major Data Privacy Gaps in Rapidly Growing Platforms*, supra.

4. An API is a protocol that allows two or more systems to exchange data by defining certain “rules” for the data transfer.

5. *Id.; Tea app Data Breach Exposes User Chats and Images*, CertPro (July 29, 2025), https://certpro.com/tea-app-data-breach/ (last visited Dec. 11, 2025).

6. *Id.*

7. *Id.*

8. *Brewing Trouble: The Steep Price of Privacy Missteps*, Smith Anderson (Aug. 18, 2025), https://www.smithlaw.com/newsroom/publications/brewing-trouble-the-steep-price-of-privacy-missteps (last visited Dec. 11, 2025).

9. *What the Tea App Incident Can Teach Us About Data Security*, Cyber Def. Mag. (Nov. 6, 2025), https://www.cyberdefensemagazine.com/what-the-tea-app-incident-can-teach-us-about-data-security/ (last visited Dec. 11, 2025).

10. *Tea Lawsuit Claims Dating App Illegally Collects, Distributes Illinois Residents' Biometric Data*, ClassAction.org (Aug. 21, 2025), https://www.classaction.org/news/tea-

lawsuit-claims-dating-app-illegally-collects-distributes-illinois-residents-biometric-data (last visited Dec. 11, 2025); Complaint at 3, *Honeycutt v. Tea Dating Advice, Inc.*, No. 2025CH08182 (Ill. Cir. Ct. filed Aug. 6, 2025), https://www.classaction.org/media/honeycutt-et-al-v-tea-dating-advice-inc-complaint.pdf (last visited Dec. 11, 2025).

11. 740 ILCS 14/1 et seq.

12. Cal. Civ. Code § 1798.100 (West 2020).

13. Cal. Civ. Code § 1798.150 (West 2020).

14. Titcombe, Stephen, *Pennsylvania's Consumer Data Privacy Act (PCDPA)*, TermsFeed (Feb. 16, 2025), https://www.termsfeed.com/blog/pennsylvania-consumer-data-privacy-act-pcdpa/#:~:text=Pennsylvania's%20Consumer%20Data%20Privacy%20Act%20(PCDPA)%20is,data%20*%20Driver's%20license%20and%20passport%20numbers (last accessed Dec. 11, 2025); Anderson Scialabba, Stephanie G., *Pennsylvania House Passes Consumer Data Privacy Act (HB 78)*, Eckert Seamans Cherin & Mellott, LLC (Oct. 15, 2025), https://www.eckertseamans.com/legal-updates/pennsylvania-house-passes-consumer-data-privacy-act-hb-78 (last accessed Dec. 11, 2025).

15. *See*, *Dittman v. Univ. of Pittsburgh Med. Ctr.*, 193 A.3d 911 (Pa. 2018) (the Pennsylvania Court held employers have a duty to protect employee data under common-law). Though the *Dittman* case centered on an employer's duty to protect employees' data, the decision is written in such a way to imposes liability on any entity that collects sensitive data.

16. Complaint, *Honeycutt v. Tea Dating Advice, Inc.*, supra.

Author



Alex Frebowitz

...

Published by the American Bar Association ©2026. Reproduced with permission. All rights reserved. This information or any portion thereof may not be copied or disseminated in any form or by any means or stored in an electronic database or retrieval system without the express written consent of the American Bar Association.

American Bar Association
https://www.americanbar.org/groups/intellectual_property_law/resources/newsletters/cloud-misconfiguration-private-right-of-action-tea-app-data-breach/